



POLITECNICO
MILANO 1863

SCUOLA DI INGEGNERIA INDUSTRIALE
E DELL'INFORMAZIONE

TESI DI LAUREA MAGISTRALE IN
COMPUTER SCIENCE AND ENGINEERING
INGEGNERIA INFORMATICA

Binary Instrumentation for Tracking Edge Coverage in Fuzzing

Author:

Scandroglio Edoardo

Student ID:

216600

Advisor:

Prof. Name Surname

Academic Year:

2026-27

Dedicated to my family.

Abstract

...

Keywords: key, words, go, here

Abstract in lingua italiana

...

Parole chiave: qui, vanno, le, parole, chiave

Contents

Abstract	i
Abstract in lingua italiana	iii
Contents	v
1 Background and Motivation	1
1.1 Fuzzing Background	1
1.2 Binary Rewriting Background	3
1.3 Problem Statement	3
1.4 State of the Art	4
1.4.1 AFL Functioning	6
Bibliography	9
List of Acronyms	11
List of Figures	13
List of Tables	15
List of Algorithms	17

1 | Background and Motivation

This chapter will focus on presenting the context of this thesis. In particular in Section 1.1 will be presented the fundamentals of fuzzing with a particular attention on coverage-guided grey-box fuzzing. In Section 1.2 is discussed the background on binary rewriting, its approaches and its difficulties. Section 1.3 states the problem addressed by this work, and Section 1.4 reviews the state of the art in binary-only fuzzing, focusing also on a description of AFL/AFL++ internals.

1.1. Fuzzing Background

Fuzzing is nowadays a widely used approach for software testing and vulnerability assessment [12, 20]. Its main strength derives from the fact that could rapidly produce various inputs to be fed into a target executable. In general a fuzzer can be divided into the **Input Generator**, that is responsible of provide inputs to the **Executor** that execute them. During the execution the **Defect Monitor** check if the input executed ends in a crash of the target.

In particular the Input Generator must choose which input provide to the executor between all the inputs in the *Input Space*. A subset of the *Input Space* is represented by the *Valid Input Space*. A good Input Generator must choose inputs that are also valid inputs, because only by doing this there is a probability of find a vulnerability[20]. So the need of a precise input selection and mutation arise, in order to discover as many edge cases as possible.

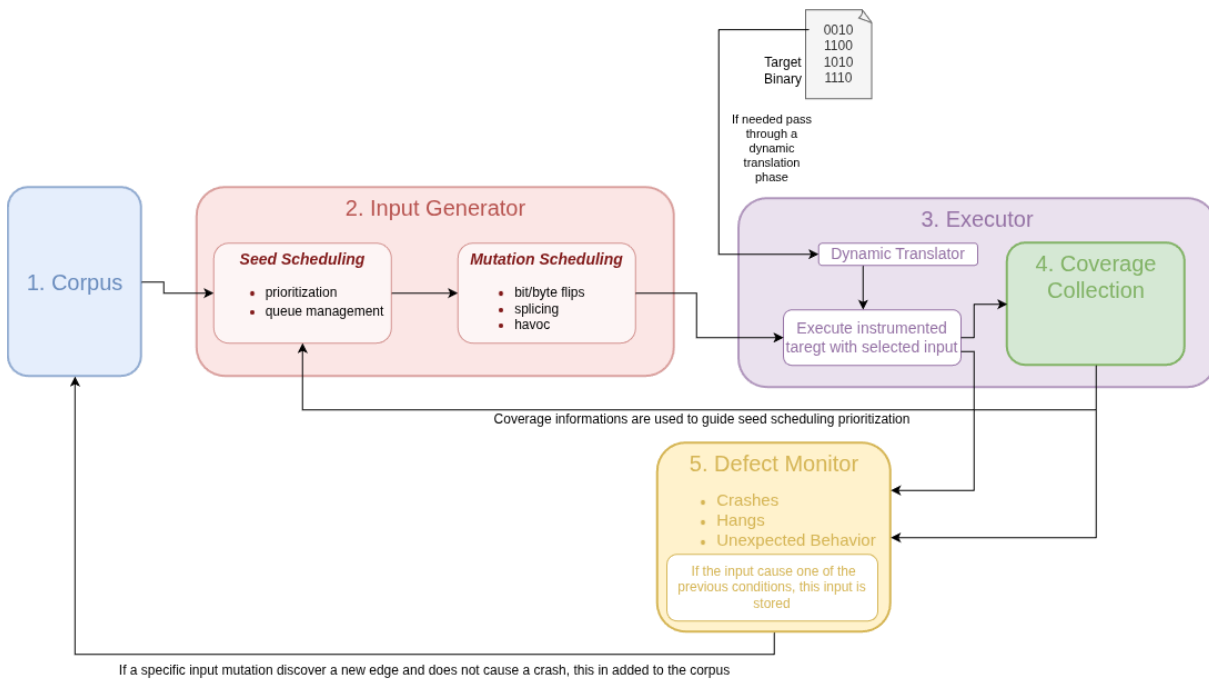
In order to do so, the Input Generator must gain some informations from the Executor. Depending on the amount of informations that the Input Generator has, fuzzing can be classified into *White-box*, *Black-box* or *Grey-box*. In Black-box fuzzing the fuzzer does not have any knowledge about the execution [14]. In White-box fuzzing instead the source code must always be available and technique of Symbolic and Concolic execution are used [7]. In Grey-box fuzzing instead the inputs are choosen using, for example, **Code Coverage** informations (i.e. number of lines of code visited during execution of the target). This approach is called *Coverage-Guided Grey-box fuzzing* and is based on prioritizing the

inputs that discover new sections of code. The best approach to Code Coverage, in terms of overhead and effectiveness, is **Edge Coverage** which keeps track of which edges in the Control Flow Graph (CFG) are taken during execution. The coverage informations are obtained through the instrumentation of the target application. Depending on the availability of the source code, the instrumentation could be added in different ways:

- The source code is available : In this case the instrumentation is added at *Compile Time*
- The source code is not available : In this case there are two different techniques to instrument the application:
 - **Static Binary Instrumentation (SBI)** : The instrumentation is added before the target is executed but without having the source code, so relying on Binary Instrumentation techniques
 - **Dynamic Binary Instrumentation (DBI)** : The instrumentation is added during the program execution

Independently from the availability of the source code, *Coverage-Guided Grey-box fuzzing* technique could be summarized as seen in fig. 1.1.

Figure 1.1: Generic diagram that describe Coverage-Guided Grey-box fuzzing workflow



Specifically for **Edge Coverage** the fig. 1.1 could be described as follows:

1. **Seed Corpus** : Represent the set of inputs on which are computed the mutations. At the beginning is composed of user defined seeds but during fuzzing this set can grow if a specific mutation discover new edges not yet discovered.
2. **Input Generator** : Is composed of two main parts:
 - **Seed Scheduling** : responsible of decide which seed in the corpus to mutate
 - **Mutation Scheduling** : responsible of decide which mutation or mutations apply to the selected seed
3. **Executor** : Is the component that actually execute the target binary. If the target binary has already been instrumented with Edge Coverage tracking instruction is executed as is, otherwise, in case of DBI a dynamic translator must dynamically instrument the binary.
4. **Coverage Collection** : In case of Edge Coverage this part is represented by the data structure used in order to keep track of which edges between Basic Block (BB) has been taken and which are not.
 These information are used, in some tools such as AFL++ [5] to guide Seed Scheduling, prioritizing inputs that, with the same level of coverage, are smaller in size and execution time.
5. **Defect Monitor** : this component check for exit status of the target to catch any crash or for an eventual timeout of the target or any other unexpected behavior of this. If none of these conditions are met, which means that the target ends normally, the coverage is checked to see if the current input had discovered a new edge. In this case the input is added to the corpus.

1.2. Binary Rewriting Background

1.3. Problem Statement

Coverage-Guided Grey-box fuzzing is one of the most effective techniques in automatic vulnerability disclosure on software [3, 15], due to its capability of generating wide amount of inputs based on the feedback obtained through Code Coverage informations that guide the fuzzer towards unexplored regions of code and therefore find hidden vulnerabilities. Infact *Black-box* fuzzing lack of a precise mutation strategy based on execution monitoring while *White-box* fuzzing incur in high overheads given by Symbolic or Concolic execution. Furthermore, the latter approach also requires the availability of the source

code, not always available. So *Grey-box* fuzzing seems to be the most promising trade-off between precision of input mutation and overheads. However, also *Grey-box* fuzzing has its own drawback. As matter of facts the effectiveness of this approach strongly depends on the availability of the source code. Infact both SBI and DBI have many limitations. The main limitation of DBI is represented by huge amount of overheads (higher than 600% overheads in case of AFL++ in QEMU-Mode [15]) that makes the exploration of a substantial part of the valid input space almost impossible. Instead SBI main difficulty arise in modifying already compiled binaries. There are several problems regarding Binary Rewriting such as Indirect Control Transfers (e.g. `call rax`), shift in binary sections or instructions that cause the need of rewrite the instructions that reference these sections and many others.

For all these reasons the preferable technique nowadays is *Compile time Edge Coverage instrumentation* with fuzzers such as AFL++, LibAFL [6] o libFuzzer [10]. However in practice, for industrial secrecy (i.e. proprietary software) or due to precompiled libraries, the applications are often closed source, and so Compile Time Edge Coverage instrumentation become unusable.

In these scenario binary only fuzzing is the only viable approach. Although SBI presents many challenges, it nonetheless proves to be the most fruitful area, given the low overheads. In this thesis I will address the problem of statically instrument a binary with Edge Coverage instructions in a way that the instrumented binary is compatible with AFL++, which has been chosen as fuzzer due to its popularity and because represent the current state of the art implementing most of the recent discovered techniques disclosed demonstrated by Andrea Fioraldi et al. [5].

The instrumentation must add as little overheads as possible with respect to compile time overheads and must preserve the correctness of the binary. This is important in fuzzing because less overheads means more executions per second, so a bigger portion of the valid input space could be visited.

1.4. State of the Art

In this section I will disclose some of the current state of the art solutions in terms of binary only greybox fuzzing, differentiating between SBI and DBI approaches.

- **DBI**

- **AFL++ in QEMU/FRIDA mode**[5] : AFL++ in QEMU mode uses QEMU in *User-mode Emulation* which consist in translating guest machine

code (i.e. guest BB) into an intermediate representation called Translation Block (TB) and subsequently append the coverage tracing instructions at the end of it. This approach is based on emulating the entire CPU thanks to QEMU virtualized environment.

Instead AFL++ in FRIDA mode [1] is based on a shared library injection in which is present a frida [17] component called **Stalker** which intercept any BB that is about to be executed, copy it into a **Code Cache** and dynamically instrument the copy with coverage tracing instructions. The execution control is then transferred to the copy, execute it, and then re-intercepted by **Stalker** at the end. Differently from QEMU mode doesn't emulate the CPU, but executed within the memory space of the target program.

- **DynamoRIO/Pin**[2, 11] : Both these approaches share the same base principle, called **Just in-time (JIT) code caching**. This consist on take control of the thread when the target application starts, and from that moment on every BB is intercepted before it is executed and is copied into a private **Code Cache**. The instrumentation is then added to the copy and the control is transferred to the code cache. The instrumentation process is more or less identical to FRIDA's Stalker mechanism, but are not optimized like this. Also in this case the implemented version uses AFL[19] as fuzzer [8, 9].

- **SBI**

- **Retrofit** [4]: This tool performs symbolic lifting on the code, replacing every reference discovered during disassembly with a symbolic label. Doing this allows instructions to be added without modifying the references, achieving reassembleable assembly. While RetroWrite can add ASan instrumentation, it cannot natively add AFL-style edge coverage instructions. To do so, the lifted assembly must be instrumented with the afl-gcc tool in order to produce the patched binary. Moreover, community-reported issues [13] document missing instrumentation points when RetroWrite's symbolized output is compiled through afl-gcc, caused by a mismatch between RetroWrite's label-naming convention and afl-as's basic-block detection heuristics. Finally, RetroWrite only works with PIE, non-stripped binaries.
- **AFL-Dyninst** [16] :

Before proceeding with the next section in which I will talk about different problems with each of the current state of the art solutions, I want to discuss the core functioning of AFL and AFL++, given its importance for understanding my approach.

1.4.1. AFL Functioning

[18]

As previously stated, AFL and especially AFL++ is one of the most used software for fuzzing binaries. AFL++ represent the community based continuation of the initial AFL project. The core functioning is virtually the same and consist in a Shared Memory (SHM) region, shared between the fuzzer and the target. The SHM dimension could vary but the default one is of 65536 bytes.

Each “cell” of the SHM contains the number of times a given Edge in the CFG has been taken during the execution of the target. Since the SHM has 65536 “cells”, each “cell” can contain a number from 0 to 255. The “cell” position is computed with a specific hash function applied to the IDs of the two BB that formed the edge. The main Edge Tracing update rule is summarized in algorithm 1.1. The line line 3 of algorithm 1.1 is used to

Algorithm 1.1 AFL Style SHM update rule

- 1: $idx \leftarrow current_bb_id \oplus previous_bb_id$
 - 2: $shared_map[idx] \leftarrow shared_map[idx] + 1$
 - 3: $previous_bb_id \leftarrow current_bb_id \gg 1$
-

avoid update the same SHM location if an edge is traversed forward or backward. An example of this could be a simple **do-while** loop as seen in algorithm 1.2 and in fig. 1.2.

The main idea behind AFL is instrumenting each basic block of a target application

Algorithm 1.2 Do-While Example

```

repeat
  {Basic Block A }
until Permanence_Condition
{Basic Block C}

```

Without line 3 of algorithm 1.1 the hash result of Edge1 will result in

$ID_A \oplus ID_B$ and the hash result of Edge2 (in case the permanence condition is not met) will result in

$ID_B \oplus ID_A = ID_A \oplus ID_B$ for xor simmetry. But since the hash is the same there will be an hash collision that cause the same “cell” to be updated two times instead on one.

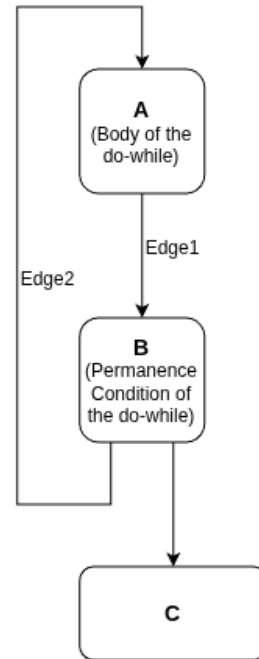


Figure 1.2: Do-while CFG

with the shared map update rule. The fuzzer initialize the SHM memory with zeros, run the instrumented target that will update the SHM with the algorithm 1.1, until it reach the end and then return to the fuzzer.

At this point the fuzzer check the just obtained SHM, that il called `trace_bits`, searching for any new discovered edge. This is done keeping a structure called `virgin_bits` that contains all the edges not yet discovered and it is initialized with ones. The compare is executed through `trace_bits  $\wedge$  virgin_bits`. If one of the position gives one after the logic AND, this means a new edge has been discovered. In this case the `virgin_bits` data structure is updated and the just executed input is saved in the corpus. Otherwise a new input is choosen, mutated and then executed.

This approach requires that for each input a `fork()` call and then an `execve()` call are performed, causing a lot of overheads for each input execution. Two main optimizations are been implemented:

- **forkserver**
- **persisten-mode** : (this available only in AFL++)

Forkserver

The forkserver makes it possible to avoid calling `execve` for every input, performing it only once at the start of execution. The forkserver is instrumented before the main of the target application. The AFL++ forkserver protocol could be summarized as follows:

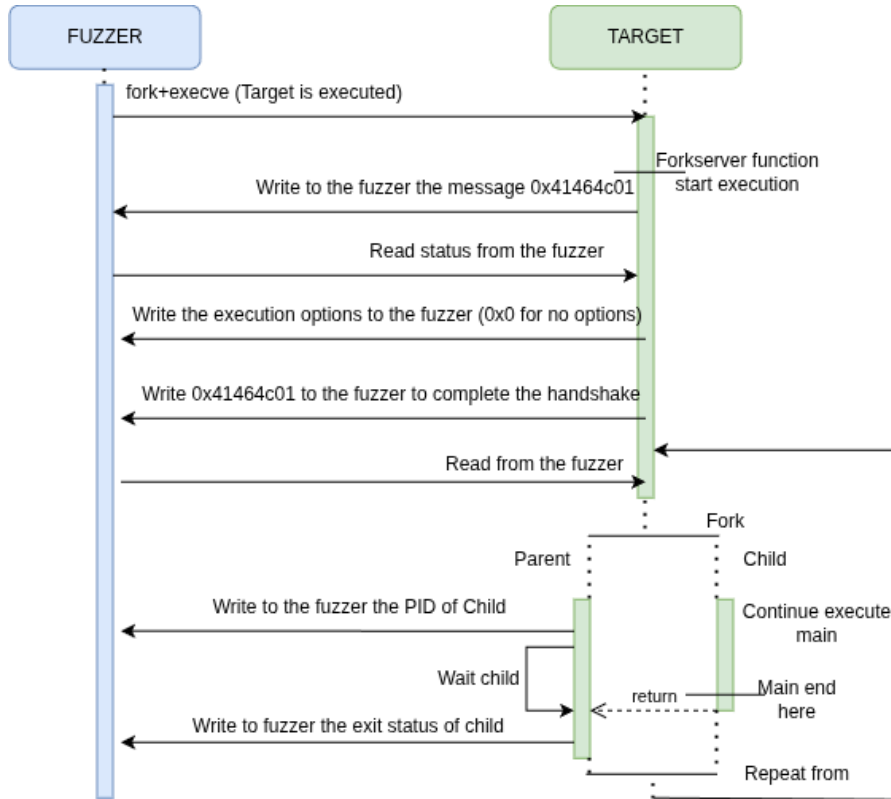
The differences between AFL forkserver protocol and AFL++ forkserver protocol are mainly the messages exchanged between forkserver and fuzzer

The communication between Fuzzer and Target seen in fig. 1.3 happens unidirectionally through two different file descriptors created by the fuzzer:

- `FORKSRV_FD` (*fd 198*): used by the forkserver to read a message sent by the fuzzer.
- `FORKSRV_FD + 1` (*fd 199*): used by the forkserver to write a message to the fuzzer.

1. The forkserver sends the “Welcome” message to the fuzzer (0x41464c01).
2. The fuzzer reply with the status code. At this point the forkserver must check if `status  $\wedge$  0xffffffff = 0x41464c01`. If it is equal continue the execution, otherwise the forkserver stops here.
3. The forkserver sends the execution options to the fuzzer. These could contains the persistent-mode or other optimizations.
4. The forkserver sends 0x41464c01 to the fuzzer to end the handshake

Figure 1.3: AFL++ Forkserver Protocol



5. The fuzzer write a message to the forkserver (its content is discarded) the handshake is finished. This message is the “go” signal for the forkserver.
6. The forkserver invoke `fork()`. The parent write the PID of the child to the fuzzer and the invoke `waitpid()`.
The child continue the execution of the main until it ends
7. When the parent exit from the `waitpid()` function (i.e. the child terminate), the exit status of the child is sent to the fuzzer and the forkserver waits for another “go” from the fuzzer.

Bibliography

- [1] AFL++ contributors. AFL++ Frida Mode. https://github.com/AFLplusplus/AFLplusplus/tree/stable/frida_mode, 2026. Accessed: 2026-09-13.
- [2] D. Bruening, T. Garnett, and S. Amarasinghe. An infrastructure for adaptive dynamic optimization. In *International Symposium on Code Generation and Optimization, 2003. CGO 2003.*, pages 265–275, 2003. doi: 10.1109/CGO.2003.1191551.
- [3] M. Böhme, V.-T. Pham, and A. Roychoudhury. Coverage-based greybox fuzzing as markov chain. In *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security, CCS16*, pages 1032–1043. ACM, Oct. 2016. doi: 10.1145/2976749.2978428.
- [4] S. Dinesh, N. Burow, D. Xu, and M. Payer. Retrowrite: Statically instrumenting cots binaries for fuzzing and sanitization. In *2020 IEEE Symposium on Security and Privacy (SP)*, pages 1497–1511, 2020. doi: 10.1109/SP40000.2020.00009.
- [5] A. Fioraldi, D. Maier, H. Eißfeldt, and M. Heuse. AFL++ : Combining incremental steps of fuzzing research. In *14th USENIX Workshop on Offensive Technologies (WOOT 20)*. USENIX Association, Aug. 2020. URL <https://www.usenix.org/conference/woot20/presentation/fioraldi>.
- [6] A. Fioraldi, D. C. Maier, D. Zhang, and D. Balzarotti. Libafl: A framework to build modular and reusable fuzzers. In *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security*, pages 1051–1065, 2022.
- [7] P. Godefroid, M. Y. Levin, and D. Molnar. Sage: whitebox fuzzing for security testing. *Communications of the ACM*, 55(3):40–44, Mar. 2012. ISSN 1557-7317. doi: 10.1145/2093548.2093564.
- [8] M. Heuse. AFL-DynamoRIO. <https://github.com/vanhauser-thc/afl-dynamorio>, 2018. Accessed: 2026-09-13.
- [9] M. Heuse. AFL-PIN. <https://github.com/vanhauser-thc/afl-pin>, 2018. Accessed: 2026-09-13.
- [10] LLVM Project. libfuzzer – a library for coverage-guided fuzz testing. <https://llvm.org/docs/LibFuzzer.html>. Accessed: 2026-09-11.

- [11] C.-K. Luk, R. Cohn, R. Muth, H. Patil, A. Klauser, G. Lowney, S. Wallace, V. J. Reddi, and K. Hazelwood. Pin: building customized program analysis tools with dynamic instrumentation. *SIGPLAN Not.*, 40(6):190–200, June 2005. ISSN 0362-1340. doi: 10.1145/1064978.1065034. URL <https://doi.org/10.1145/1064978.1065034>.
- [12] S. Malliserry and Y.-S. Wu. Demystify the fuzzing methods: A comprehensive survey. *ACM Computing Surveys*, 56(3):1–38, Oct. 2023. ISSN 1557-7341. doi: 10.1145/3623375.
- [13] Marsman1996. Missing some instrumentations when instrumenting binary with AFL. <https://github.com/HexHive/retrowrite/issues/28>, Aug. 2021. GitHub Issue #28, HexHive/retrowrite repository. Accessed: 2026-09-13.
- [14] B. P. Miller, L. Fredriksen, and B. So. An empirical study of the reliability of unix utilities. *Communications of the ACM*, 33(12):32–44, Dec. 1990. ISSN 1557-7317. doi: 10.1145/96267.96279.
- [15] S. Nagy, A. Nguyen-Tuong, J. D. Hiser, J. W. Davidson, and M. Hicks. Breaking through binaries: Compiler-quality instrumentation for better binary-only fuzzing. In *30th USENIX Security Symposium (USENIX Security 21)*, pages 1683–1700. USENIX Association, Aug. 2021. ISBN 978-1-939133-24-3. URL <https://www.usenix.org/conference/usenixsecurity21/presentation/nagy>.
- [16] Paradyn Tools Project. Dyninst API. <https://dyninst.org/dyninst>, 2018. Accessed: 2026-09-13.
- [17] O. A. V. Ravnås. Frida: Dynamic instrumentation toolkit for developers, reverse-engineers, and security researchers, 2026. URL <https://github.com/frida/frida>.
- [18] M. Zalewski. Technical "whitepaper" for afl-fuzz. https://github.com/google/AFL/blob/master/docs/technical_details.txt. Accessed: 2026-09-19.
- [19] M. Zalewski. American Fuzzy Lop. <http://lcamtuf.coredump.cx/afl/>, 2017. Accessed: 2026-09-13.
- [20] X. Zhu, S. Wen, S. Camtepe, and Y. Xiang. Fuzzing: A survey for roadmap. *ACM Computing Surveys*, 54(11s):1–36, Jan. 2022. ISSN 1557-7341. doi: 10.1145/3512345.

List of Acronyms

BB Basic Block. 3, 5, 6

CFG Control Flow Graph. 2, 6

DBI Dynamic Binary Instrumentation. 2–4

JIT Just in-time. 5

SBI Static Binary Instrumentation. 2, 4, 5

SHM Shared Memory. 6

TB Translation Block. 5

List of Figures

1.1	Generic diagram that describe Coverage-Guided Grey-box fuzzing workflow . . .	2
1.2	Do-while CFG	6
1.3	AFL++ Forkserver Protocol	8

List of Tables

List of Algorithms

1.1	AFL Style SHM update rule	6
1.2	Do-While Example	6

